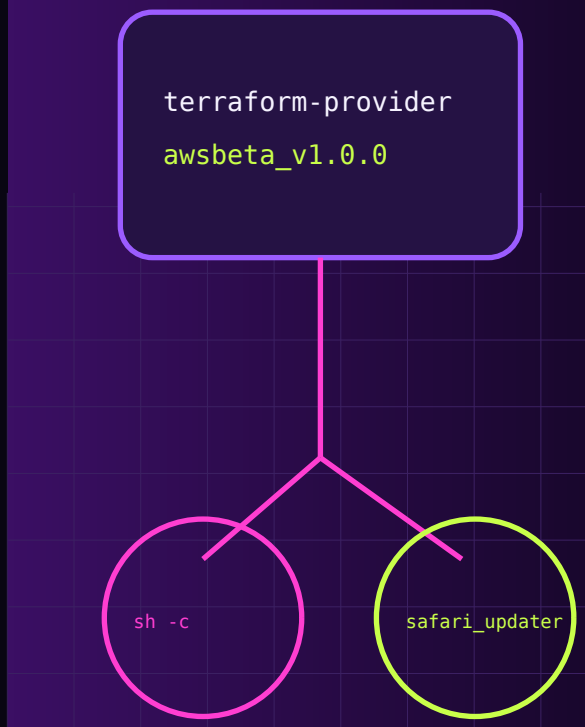
THREAT ANALYSIS

Trojanized Terraform Provider Launches a Temporary Bash Loader

Campaign-specific process hunting for a source-observed provider → shell execution chain.



TRADERTRAITOR / TERRAFORM / LINUX & macOS

HUNTING · CONFIDENCE MEDIUM · UNTESTED

EXECUTIVE ASSESSMENT

Actionable Hunt, Not a Production Rule

The evidence supports a narrow first-stage process hunt. It does not justify attribution-led alerting or a durable behavioral production rule.

- **Decision**

  Classification: Hunting query — Untested implementation sketch. Confidence: Medium. Operational Value: 8/10.

- **Why it matters**

  The source documents a trojanized Terraform provider starting a temporary Bash loader through sh -c, a direct and investigable parent-child relationship.

- **Why not production**

  The provider filename and safari_updater artifact are mutable campaign identifiers. Benign overlap is low but environment execution and field population remain untested.

- **Supported**

  Observed first-stage provider execution and shell launch; direct endpoint process telemetry; exact source-observed artifacts.

- **Not supported**

  Successful payload retrieval, later-stage execution, C2, credential theft, compromise impact, or independent high-confidence attribution.

Observed Execution Chain

Facts, vendor interpretation, inference, and assumptions are separated to keep the hunt technically defensible.

- **Source facts**

  ThreatLabz observed terraform-provider-awsbeta_v1.0.0 executing malicious code when Terraform starts the provider. When session.lock is absent, it writes safari_updater to a temporary directory, marks it executable, and starts it through sh -c as a detached child.

- **Vendor interpretation**

  ThreatLabz assesses the activity as suspected TraderTraitor and describes the provider as masquerading as a legitimate AWS Terraform provider.

- **Analyst inference**

  A direct endpoint parent-child record should exist when the provider starts sh or bash with a command line referencing safari_updater.

- **Assumptions**

  Microsoft Defender for Endpoint is deployed and ProcessCommandLine plus InitiatingProcessFileName are populated on affected Linux or macOS endpoints.

- **Unconfirmed**

  The hunt does not confirm whether the script downloaded a payload, whether later stages ran, or whether any observed match is malicious without triage.

TELEMETRY CONTRACT

Required Endpoint Evidence

Primary platform: Microsoft Defender XDR because DeviceProcessEvents exposes direct process and initiating-process fields without a custom parser.

- **Required**

  DeviceProcessEvents — documented table populated by Microsoft Defender for Endpoint.

- **Required fields**

  Timestamp, DeviceId, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessFolderPath, and InitiatingProcessCommandLine — documented.

- **Optional enrichment**

  AccountName, FolderPath, SHA1, ReportId — documented and projected for context; not used as predicates.

- **Unavailable**

  Script body, download response, file content, payload execution success, and encrypted traffic content are not observable from this process query.

PRIMARY IMPLEMENTATION

Defender XDR Advanced Hunting

Hunting query — Untested implementation sketch. Every predicate maps to the source-observed first-stage process behavior.

```
DeviceProcessEvents
| where InitiatingProcessFileName =~
    "terraform-provider-awsbeta_v1.0.0"
| where FileName in~ ("sh", "bash")
| where ProcessCommandLine contains "safari_updater"
| where ProcessCommandLine contains "-c"
| project Timestamp, DeviceId, DeviceName, AccountName,
    FileName, FolderPath, ProcessCommandLine, SHA1,
    InitiatingProcessFileName, InitiatingProcessFolderPath,
    InitiatingProcessCommandLine, ReportId
| order by Timestamp desc
```

PREDICATE EVIDENCE

- **Parent**
  Exact provider name is source-observed; equality avoids expanding to unrelated Terraform providers.
- **Child and arguments**
  sh -c and safari_updater are source-observed. No time threshold, rarity claim, join, or inferred download success is used.

False Positives and Investigation

The narrow artifact pair should keep volume low, but a match remains a lead—not proof of compromise.

- **Expected overlap**

  Malware analysis, red-team emulation, incident-response replay, developer testing, or a copied sample in a controlled lab.

- **Allowlisting**

  Allowlist only verified lab devices, approved test accounts, or signed internal test artifacts. Do not suppress on username or developer role alone.

- **Triage**

  Confirm provider origin, package/source repository, command-line integrity, temporary path, file hash, signer or provenance where available, and adjacent file/network events.

- **Failure conditions**

  Sensor absent; unsupported OS telemetry; truncated command line; provider launched through an intermediate process; renamed provider or loader; shell telemetry excluded.

- **Durability**

  Artifact-specific. Retain as a campaign hunt and pivot from matches to broader local baselining before designing a behavioral rule.

VALIDATION GATES

Promote, Reject, or Retire

Use controlled execution and real telemetry to decide whether this sketch is useful in the target environment.

- **1 · Schema**

  Confirm DeviceProcessEvents ingests Linux/macOS Terraform execution and required parent/command-line fields are populated.

- **2 · Positive test**

  Execute a benign provider-shaped test process that starts sh -c with a safari_updater marker in an isolated lab; expect one directly attributable match.

- **3 · Negative baseline**

  Run against the normal engineering retention window and review all Terraform-related shell children; do not infer rarity before this baseline.

- **Success**

  Required fields are populated, the controlled chain is returned, and benign overlap is explainable with narrow environment-specific exclusions.

- **Rejection**

  The controlled chain is missed, command lines are absent/truncated, or legitimate workflows reproduce the complete artifact pair at unacceptable volume.

- **Secondary SIEMs**

  Splunk and Chronicle: no reliable implementation can currently be written. Validate raw endpoint source, parser/sourcetype or UDM mapping, parent field, command line, and one sample event first.

Detection Engineering Verdict

Preserve the exact campaign hunt, validate telemetry, and resist promoting mutable artifacts into a durable production rule.

- **Deploy as a hunt**
  Use the KQL sketch for retrospective and targeted investigation after validating Linux/macOS endpoint coverage.
- **ATT&CK**
  T1059.004 Unix Shell; T1036.005 Match Legitimate Resource Name or Location. No additional techniques are claimed.

PRIMARY RESEARCH

Zscaler ThreatLabz — “Suspected TraderTraitor Group Uses Trojanized Terraform Provider to Deliver Cross-Platform Malware” — published 8 October 2026; activity observed July 2026.

hxxps://www[.]zscaler[.]com/blogs/security-research/suspected-tradertraitor-group-uses-trojanized-terraform-provider-deliver

OFFICIAL SCHEMA

Microsoft Learn — DeviceProcessEvents table in the advanced hunting schema — accessed 15 October 2026.

hxxps://learn[.]microsoft[.]com/defender-xdr/advanced-hunting-deviceprocessevents-table